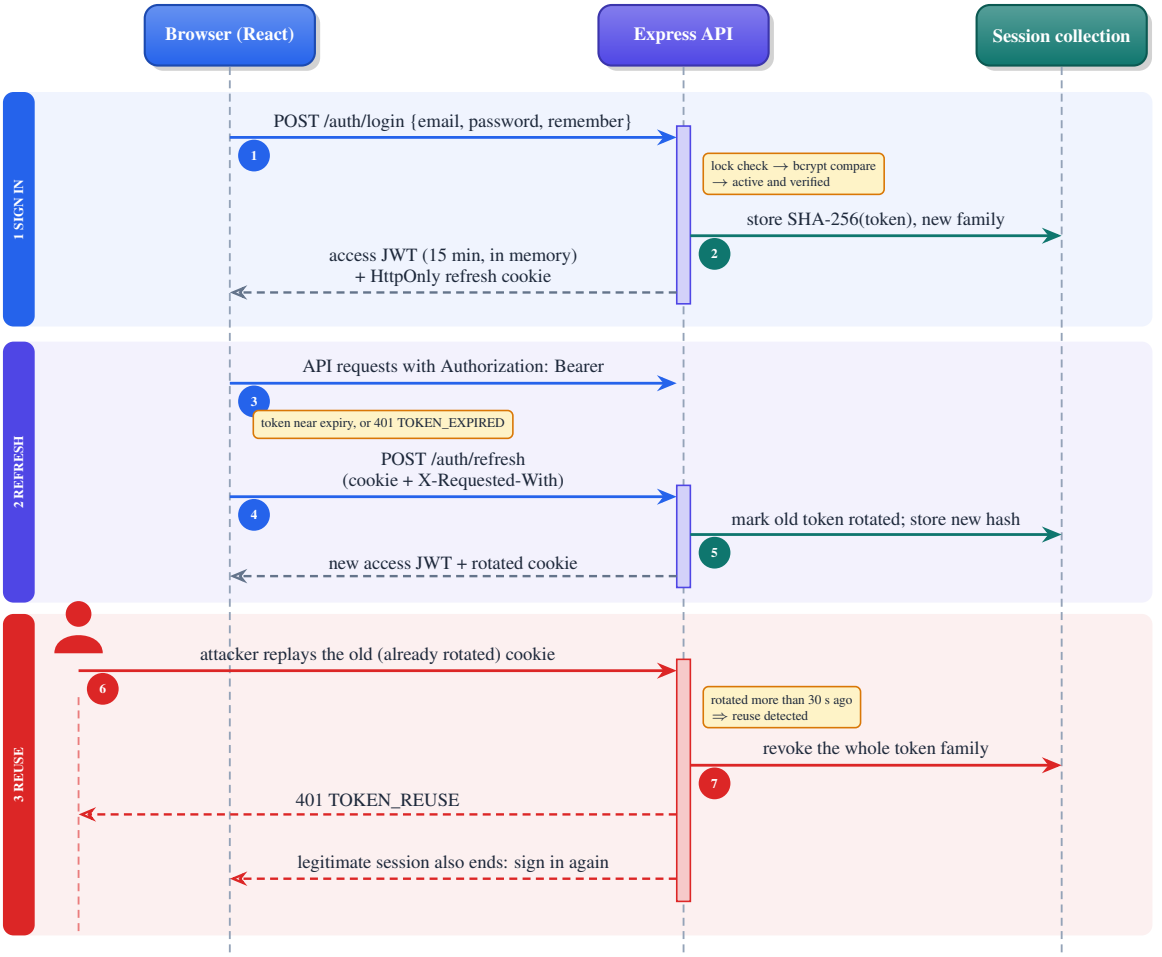
Browser (React)
Express API
Session collection
1 SIGN IN
POST /auth/login {email, password, remember}
1
lock check → bcrypt compare
→ active and verified
store SHA-256(token), new family
2
access JWT (15 min, in memory)
+ HttpOnly refresh cookie
2 REFRESH
API requests with Authorization: Bearer
3
token near expiry, or 401 TOKEN_EXPIRED
POST /auth/refresh
(cookie + X-Requested-With)
4
mark old token rotated; store new hash
5
new access JWT + rotated cookie
3 REUSE
attacker replays the old (already rotated) cookie
6
rotated more than 30 s ago
⇒ reuse detected
revoke the whole token family
7
401 TOKEN_REUSE
legitimate session also ends: sign in again